Simulazione Spear-Phishing & Adversarial AI

Target: Kim Kardashian

Metodologia di indagine

L'indagine è stata condotta in due fasi:

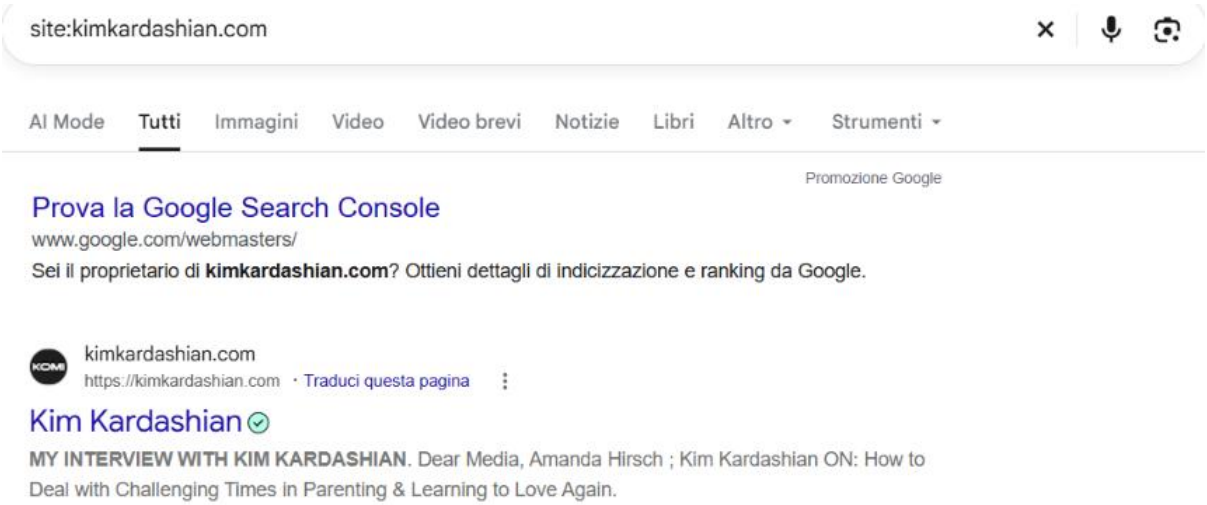
Fase 1: Google Dorking per raccolta informazioni da fonti aperte

Fase 2: Maltego per mappatura delle connessioni

Fase 1: Google Dorking

DORK 1: site:kimkardashian.com

Utilizzato per restringe la ricerca esclusivamente al dominio ufficiale kimkardashian.com.



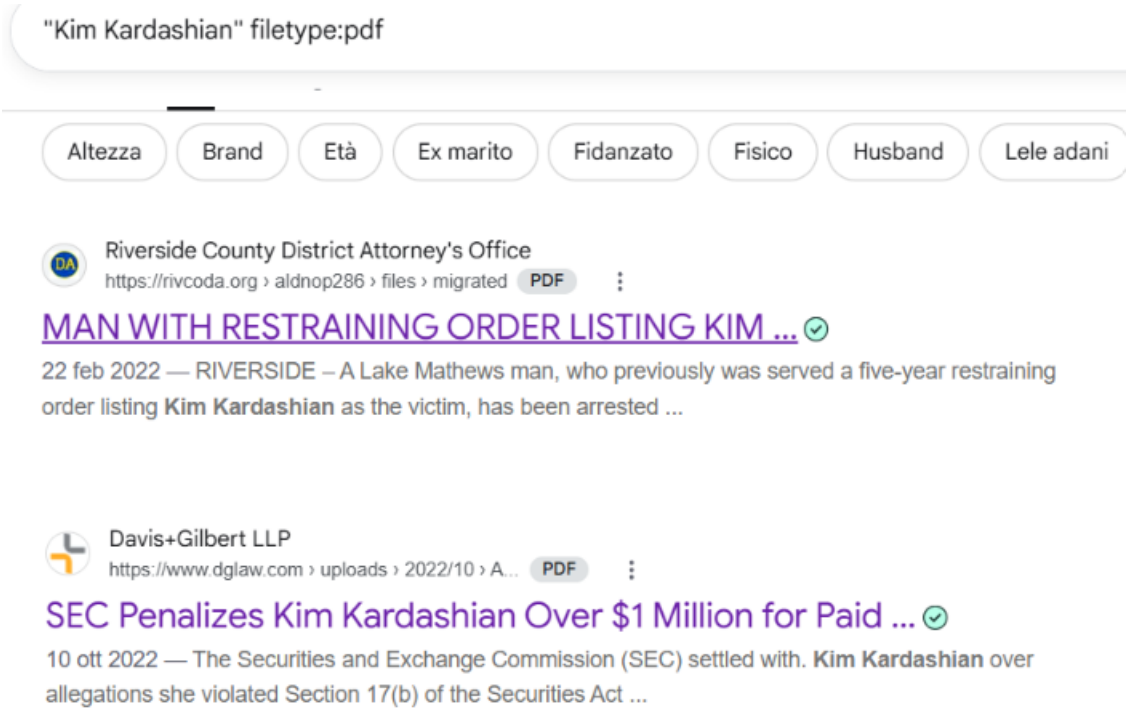
Presenza di contenuti personali che potrebbero essere usati per personalizzare attacchi di phishing (es. e-mail che citano l'intervista).

DORK 2: "Kim Kardashian" filetype:pdf

Utilizzato per cercare documenti PDF che menzionano "Kim Kardashian" su tutto il web (documenti legali, contratti, comunicati ufficiali.)

1. **Documento legale - Riverside County District Attorney's Office:** "MAN WITH RESTRAINING ORDER LISTING KIM..." - Un uomo con ordine restrittivo di 5 anni, Kim Kardashian come vittima è stato arrestato (22 feb 2022).

2. **Documento SEC - Davis+Gilbert LLP:** "SEC Penalizes Kim Kardashian Over $1 Million for Paid..." - La SEC ha multato Kim Kardashian per più di $1 milione per violazioni della Securities Act (10 ott 2022).



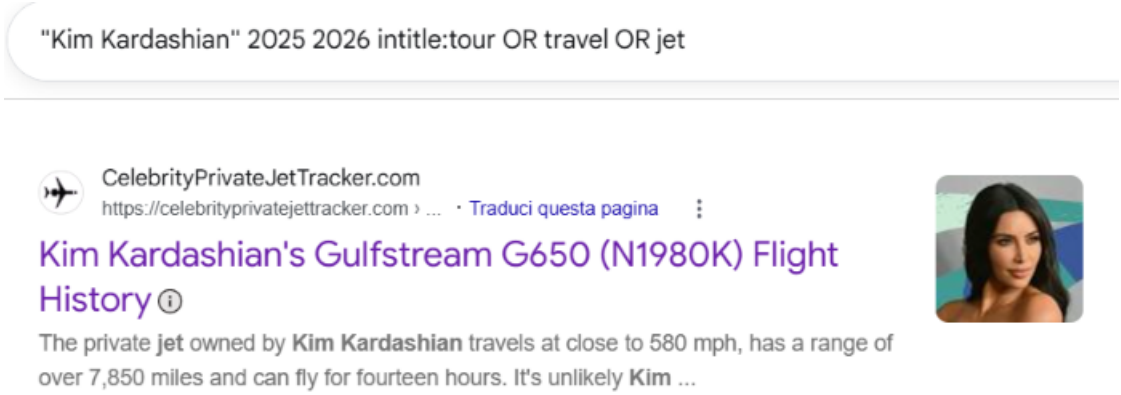


- Esistono stalkers con ordini restrittivi
- **Problemi legali/finanziari:** Multa SEC per promozione criptovalute (EthereumMax)

DORK 3: "Kim Kardashian" 2025 2026 intitle:tour OR travel OR jet

Utilizzato per cercare articoli recenti (2025-2026) con parole relative a viaggi, tour o jet privati nel titolo.

- CelebrityPrivateJetTracker.com: "Kim Kardashian's Gulfstream G650 (N1980K) Flight History"
- velocità 580 mph, autonomia 7.850 miglia, 14 ore di volo



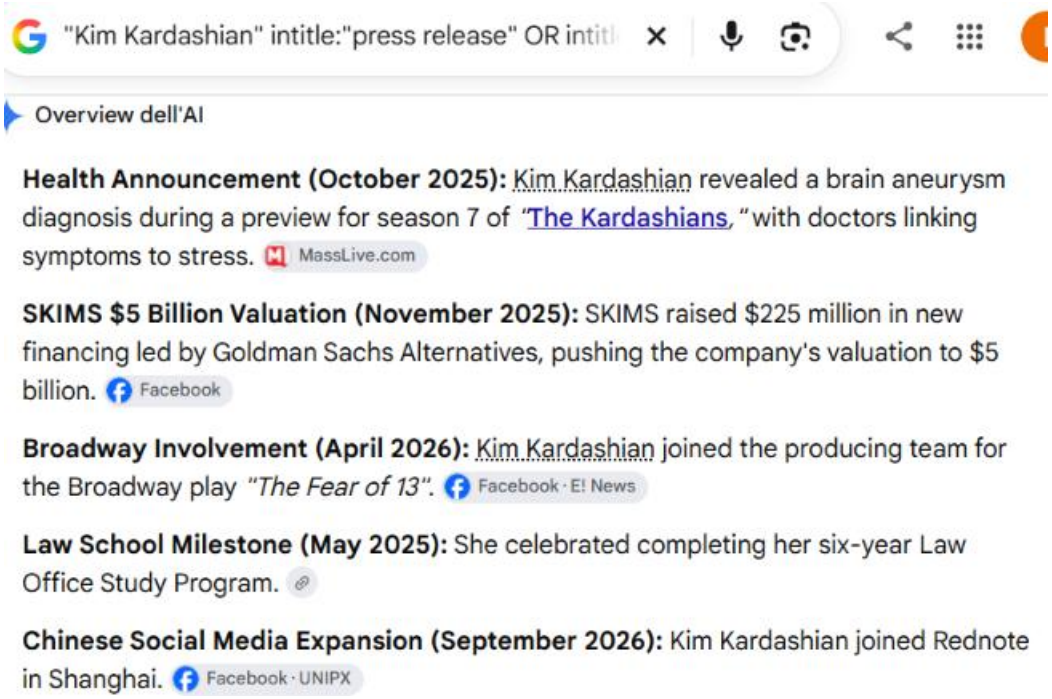
- Jet privato identificato: Gulfstream G650
- Targa di registrazione: N1980
- I movimenti del jet sono tracciabili pubblicamente, e rivelano spostamenti e localizzazione del target in tempo reale

DORK 4: "Kim Kardashian" intitle:"press release" OR intitle:"announcement"

Utilizzato per cercare comunicati stampa e annunci ufficiali.

Risultati trovati:

1. **Health Announcement (October 2025):** Diagnosi di aneurisma cerebrale durante la stagione 7 di "The Kardashians"
2. **SKIMS $5 Billion Valuation (November 2025):** SKIMS ha raccolto $225 milioni con Goldman Sachs Alternatives
3. **Broadway Involvement (April 2026):** Kim entra nel team di produzione di "The Fear of 13"
4. **Law School Milestone (May 2025):** Completamento programma di studio legale di 6 anni
5. **Chinese Social Media Expansion (September 2026):** Kim si unisce a Rednote a Shanghai



Informazioni operative:

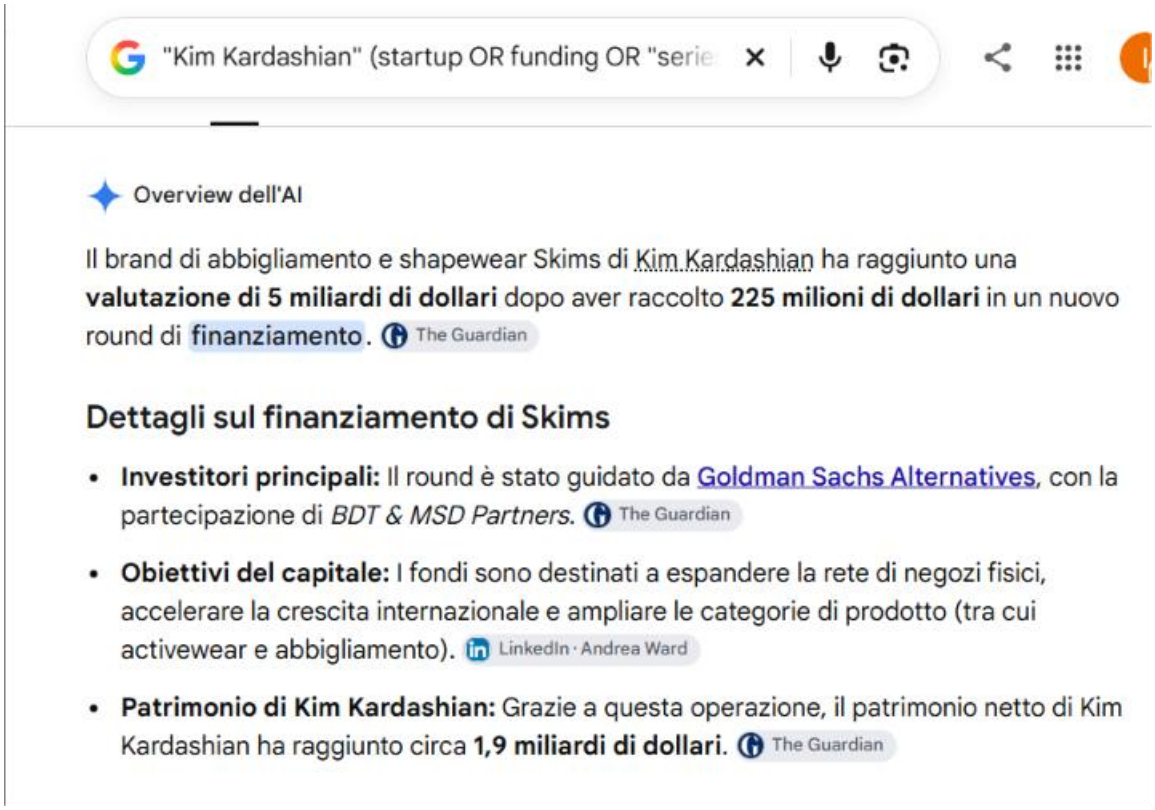
- **Valutazione aziendale:** SKIMS vale $5 miliardi
- **Problemi di salute:** Aneurisma cerebrale (potenziale vettore di phishing emotivo)
- **Nuovi progetti:** Broadway, espansione Cina
- **Formazione legale:** Completamento law school

DORK 5: "Kim Kardashian" (startup OR funding OR "series A" OR investor)

Usato per cercare informazioni su investimenti, finanziamenti e startup collegate al target.

Risultati trovati:

- **Investitori principali:** Goldman Sachs Alternatives, BDT & MSD Partners
- **Obiettivi del capitale:** Espansione rete negozi fisici, crescita internazionale, nuove categorie prodotto (activewear)
- **Patrimonio netto Kim Kardashian:** ~$1,9 miliardi

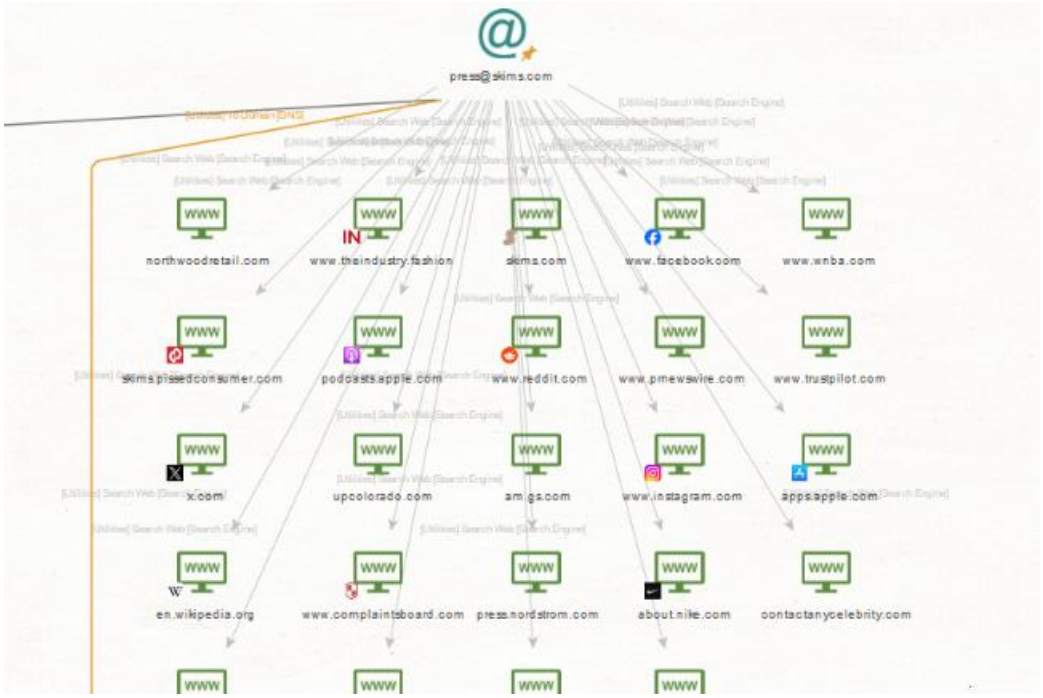


Informazioni operative:

- **Partner finanziari di alto profilo:** Goldman Sachs, BDT & MSD Partners
- **Espansione internazionale in corso** (nuovi mercati = nuovi vettori di attacco)

Fase 2: Maltego

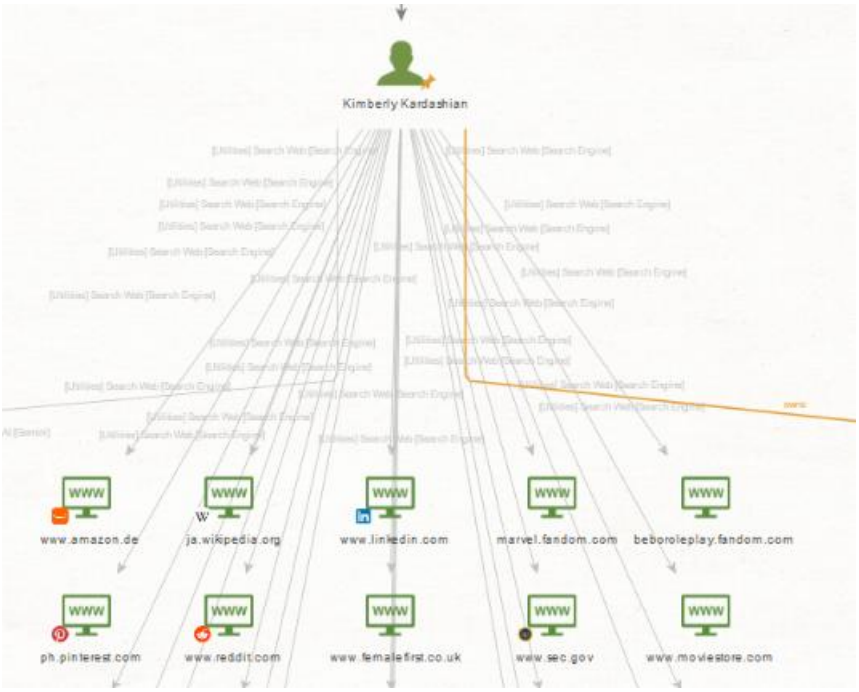
GRAFICO 1: press@skims.com



Il nodo press@skims.com (Email Address) è stato usato come punto di partenza per la transform Search Web.

- **Email di contatto pubblico:** press@skims.com

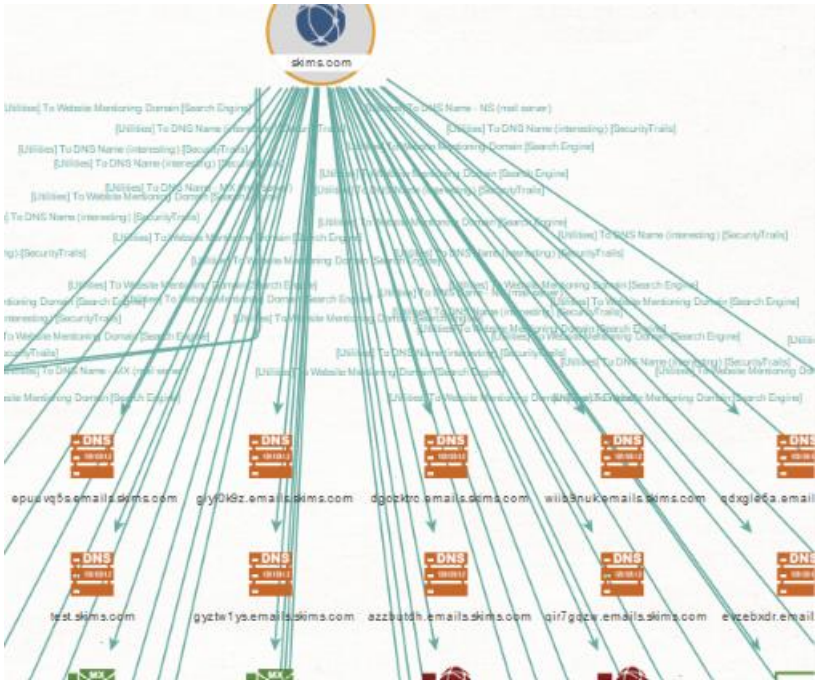
GRAFICO 2: Kimberly Kardashian (Person)



Kimberly Kardashian è stato collegato tramite Search Web a numerosi siti:

- **Documento SEC confermato:** Il nodo sec.gov collega direttamente al documento di penalizzazione.

GRAFICO 3: skims.com - Analisi DNS



La transform To DNS Name su skims.com ha rivelato:

Provider identificato: Cloudflare (protezione DDoS e CDN)

Informazioni Non cancellate





Fase 3: Phishing Scenario SEC/Legale

Scenario di attacco: Falsa comunicazione Sec

- **Mittente fittizio**: SEC - Securities and Exchange Commission (Division of Corporation Finance)
- E-mail: (legal-notice@sec-gov-portal.com invece di @sec.gov)
- **Target specifico**: Team legale di Kim Kardashian Davis+Gilbert (studio legale)

- Subito dopo il finanziamento SKIMS da $225M.

Obiettivo dell'attacco:

- Credenziali di accesso al portale finanziario SKIMS/Goldman Sachs
- Installazione malware tramite allegato PDF (finto documento di notifica SEC)
- Furto di dati finanziari riservati relativi all'investimento Goldman Sachs Alternatives

1. Autorità

Mittente: Ente governativo federale USA

Riferimenti a leggi specifiche Securities Act 17(b) Norma antifrode

Uso di linguaggio legale formale

Citazione caso precedente reale (multa $1M del 2022)

2. Urgenza

"Risposta obbligatoria entro 48 ore"

"Scadenza legale improrogabile"

"Sanzioni aggiuntive in caso di mancata compliance"

3. Scaristà

"Documento classificato - accesso riservato"

"Solo il destinatario autorizzato può visualizzare"

"Non inoltrare - violazione federale"

ESEMPIO FITTIZIO: Email di Spear-Phishing

Header Email

- **Mittente:** `legal-notice@sec-gov-portal.com`
- **A:** `compliance@davisgilbert.com` (Fittizio, per scopo didattico)
- **Oggetto:** URGENTE: Avviso di Conformità Sec. 17(b) – Richiesta Documentazione Obbligatoria (Rif. EthereumMax / SKIMS) – Scadenza 48h

Corpo dell'Email

> **U.S. Securities and Exchange Commission**
> *Division of Enforcement – Compliance Portal*
> Spettabile Team Legale Davis+Gilbert LLP,
> Facciamo seguito alle precedenti sanzioni amministrative irrogate nel 2022 (Rif. Azione SEC n. 2022-234, violazione Securities Act Section 17(b) relativa alla promozione di EthereumMax) per notificare una nuova procedura di verifica obbligatoria.
> A seguito della recente operazione di raccolta fondi da $225M da parte di Goldman Sachs Alternatives (Novembre 2025, valutazione $5B) per l'entità SKIMS, la Commissione ha identificato una discrepanza nei filed documentali che richiede una chiarificazione immediata per evitare l'applicazione di sanzioni supplementari e il blocco preventivo delle attività correlate.

In qualità di rappresentanti legali accreditati, siete tenuti ad accedere al **Portale Riservato di Conformità SEC** per visualizzare il documento formale di notifica e caricare la documentazione richiesta.

🔗 **Accedi al Portale Riservato SEC** ↗

(Link visualizzato come testo, ma puntante a un dominio non governativo)

⚠️ **AVVISO URGENTE:** La scadenza per la conformità è tassativamente fissata a **48 ore** dalla ricezione della presente (entro il 8 Novembre 2026, ore 23:59 EST). Il mancato accesso comporterà l'emissione automatica di un ordine di comparizione e sanzioni pecuniarie giornaliere.

In allegato trovate una copia di riferimento del preavviso: `SEC_Notice_2026_KK.pdf`.

Per qualsiasi domanda, fare riferimento esclusivamente a questo canale di comunicazione riservato.

Cordialmente,

Ufficio di Conformità e Verifica

U.S. Securities and Exchange Commission

Questo è un messaggio generato automaticamente. Non rispondere a questa email.

Indicatori di Compromissione e Anomalie

L'email presenta 6 red flags:

- La SEC utilizza esclusivamente il dominio @sec.gov per tutte le comunicazioni ufficiali. Il dominio "sec-gov-portal.com" è un esempio di typosquatting: sfrutta la somiglianza visiva con "sec.gov" per ingannare il destinatario.
- Richiesta: "accedere al Portale Riservato di Conformità SEC per visualizzare il documento formale". SEC non richiede mai l'inserimento di credenziali tramite link e-mail. L'accesso ai portali SEC avviene tramite: Autenticazione diretta su sec.gov; Sistema EDGAR con credenziali pre-registrate.
- Le comunicazioni SEC reali prevedono altre tempistiche (tipicamente 30-90 giorni per compliance documentale). Una scadenza di 48 ore con minaccia di sanzioni immediate è incompatibile con le procedure amministrative federali USA. Bisognerebbe consultare le linee guida SEC ufficiali sui tempi di risposta per notifiche di conformità.
- SEC non invia documenti ufficiali come allegati e-mail. I documenti formali sono pubblicati esclusivamente su: Portale EDGAR (edgar.sec.gov); Sito ufficiale sec.gov/litigation.
- Tentativo deliberato di impedire verifiche incrociate. Un vero ente governativo fornisce sempre: Numeri di telefono ufficiali verificabili; Riferimenti a uffici regionali; Possibilità di contattare il case officer direttamente.
- Assenza di dettagli verificabili: Le comunicazioni SEC formali includono sempre: File Number del caso; Nome e contatti del Enforcement Attorney; Riferimenti precisi agli ordini del tribunale.